# Platform Owner Guide — PhysioGuidance

**For:** Amna (Platform Owner) **Purpose:** The definitive "how do I run this thing" manual — daily operations, common tasks, emergency runbooks, and every place to look when something is unclear. **Handover date:** 2026-08-17 **Version:** 1.0

> **Read once cover-to-cover.** Then use §16 as your daily/weekly checklist and §11–§12 as reference when something goes wrong.

---

## Table of contents


1. What PhysioGuidance is
2. Architecture at a glance
3. People and roles
4. Your admin dashboard tour
5. Daily operations
6. Weekly operations
7. Monthly operations
8. Common runbooks
9. Emergency runbooks
10. Deployment — how code gets to production
11. Cost management
12. Compliance runbook (PDPL / NELC / SDAIA)
13. What we intentionally did NOT build
14. Where to find things
15. Escalation path
16. Cadence checklist (print this)


---

## 1. What PhysioGuidance is

- **Platform:** NELC-accredited Learning Management System for continuing physiotherapy education in Saudi Arabia.
- **Users:** Physiotherapists (students) enrolling in CME-eligible courses, instructors teaching those courses, admins managing the whole platform.
- **Delivery types:** Live Zoom sessions (with attendance tracking), pre-recorded course modules with assessments, and webinar courses (attendance-only CME).
- **Compliance stack:** PDPL (Saudi personal data protection), NELC (education accreditation), SDAIA (Saudi region residency + audit).
- **Revenue model:** Paid course enrollments (Moyasar, Tamara, Tabby, bank transfer) with automatic invoicing.
- **Region:** Everything runs in `me-central2` (Dammam). This is mandatory — do not deploy anything to any other region.

---

## 2. Architecture at a glance




**All 5 Cloud Run services + 25 batch jobs live in me-central2** and are deployed from `.github/workflows/deploy-*.yml`. Each service runs under a **per-service service account** (not the default compute SA) with least-privilege IAM.

**Sources of truth:**

- Course content, users, payments, certificates → Cloud SQL ( `physioguidance-db-me` )
- Blog + marketing content → Strapi CMS (same Postgres, separate schema)
- User uploads (avatars, receipts, materials) → GCS buckets
- Application secrets → Secret Manager (mounted into Cloud Run at start)

# 3. People and roles

| Role | Scope | Where they log in |
|---|---|---|
| **Super Admin** | You. Everything. | `/dashboard/admin` |
| **Admin** | Same as Super Admin except cannot promote to Super Admin. | `/dashboard/admin` |
| **Finance** | Payments, refunds, invoices, bank-transfer review. Cannot manage users or courses. | `/dashboard/admin` (limited menu) |
| **Manager** | Read-only across most areas, plus can approve instructor applications. | `/dashboard/manager` |
| **Instructor** | Own courses, own sessions, own students, own attendance. | `/dashboard/instructor` |
| **Student** | Own enrollments, own certificates, own profile. | `/dashboard/student` |
| **Support Team** | Support tickets only. | `/dashboard/admin/support` |

**Promoting a user:** Admin → Users → find user → change role. The change is immediate. See §8.1 for the runbook.

**Impersonation is NOT built.** If you need to see what a specific student sees, log in as a real test student account.

# 4. Your admin dashboard tour

Log in at `https://app.physioguidance.org/dashboard/admin`. The left sidebar (top → bottom) is arranged in domain order:

## Overview

- **Dashboard** — high-level KPIs (new users today, revenue this week, active sessions, pending approvals). Start your day here.

## People

- **Users** — every account. Filter by role, status, verification. Bulk-suspend, promote, or reset password.

- **Role Requests** — physiotherapists asking to become instructors. Badge = pending count.
- **Support** — support tickets. Assign, reply, close.
- **Looped-in** — internal collaborators pulled into support threads for context.

### Learning

- **Courses** — every course. Approve, publish, unpublish, edit metadata.
- **Certificates** — issued CME certificates. Regenerate, revoke, verify.

### Engagement

- **Points** — reward-points balances and rules. Adjust manually for edge cases.

### Money

- **Finance** — payments queue, refunds, bank-transfer approvals, invoice archive.

### Insights & Governance

- **Reports** — pre-built exports (enrollments per course, revenue by month, attendance by session).
- **Compliance** — NELC-facing evidence (SCFHS export, CPD activity register).
- **NELC Integration** — xAPI LRS status, statement retry queue.
- **Logs** — audit trail. Every meaningful action is here. This is your primary forensic tool.
- **Security** — 2FA status, active sessions, lockout thresholds.
- **Monitoring** — live infrastructure health (services, jobs, resources). See malware-unscanned-file-gate.md + redis-persistence-risk.md for context on what each widget shows.

### Config

- **Templates** — email templates (transactional). Edit copy, preview in EN and AR.
- **Settings** — everything else: brand, maintenance mode, feature flags, gateway credentials, admin preferences.

**Every page has a "Help?" tooltip on unfamiliar terms.** If it doesn't, that's a bug — file it.

---

## 5. Daily operations (≤10 min)

**Every business morning, in this order:**

1. **Open Monitoring page.** All services green? All uptime checks passing? Cloud SQL + Redis stable? If any red, drop to §9.1.

2. **Check pending bank-transfer receipts** (Finance → Bank Transfers → Pending). Age > 24h = flag for review that day.
3. **Check pending role requests** (People → Role Requests, badge shows count). Approve or reject within 48h SLA.
4. **Check pending support tickets** (People → Support). Any unassigned? Assign.
5. **Skim the Logs page** (Insights → Logs). Filter to last 12h. Look for any `severity=error` or unusual admin action (e.g. mass user delete).
6. **Check Sentry for spikes.** Bookmark: your Sentry project. If today's error rate is >2x yesterday, investigate.

If everything is quiet, close the tab. You do not need to babysit the platform.

---

# 6. Weekly operations (~30 min, pick one day)

1. **Cost review.** GCP Console → Billing → Reports. Look at last 7 days vs prior 7 days. If cost > 20% up, drop to §11.
2. **User growth review.** Admin → Reports → Users. Look at signups trend. If growth flat while marketing spending, escalate to team.
3. **Certificate audit.** Compliance → Certificates → issued this week. Random-spot-check 3 — verify enrollment → attendance → assessment chain.
4. **Refund queue.** Finance → Refunds. Any older than 7 days? Push to finalize or reject.
5. **Backup verification.** GCP Console → Cloud SQL → `physioguidance-db-me` → Backups. Confirm last 7 daily backups exist. See §9.2 for restore drill.

---

# 7. Monthly operations (~2 hours, first Monday)

1. **Secrets check.** Any secret rotated more than 12 months ago? See secrets-rotation-plan.md — plan rotation for next month.
2. **Access audit.** GCP Console → IAM. Who has `Owner` or `Editor`? Anyone who left the team? Revoke immediately.
3. **PDPL request log review.** Admin → Compliance → PDPL Requests. Any pending erasure or portability requests past 30-day SLA? Escalate.
4. **NELC evidence refresh.** Compliance → NELC Evidence → export current month's activity register. Save to shared drive.
5. **Cost forecast.** GCP Billing → Forecast → is next month's projection within budget (1,000 SAR)? If not, drop to §11.

6. **Read the top 3 items in `.claude/projects/-Users-macbookair-Developer-physioguidance/memory/MEMORY.md`.** Anything stale? Update.

---

# 8. Common runbooks

## 8.1 Promote a user to Admin or Finance

1. Admin → Users → search for the user (email works).
2. Click into their profile.
3. Change **Role** dropdown → save.
4. The user's next login shows the new dashboard. No email is auto-sent — you tell them.

## 8.2 Approve a bank-transfer receipt

1. Finance → Bank Transfers → Pending queue.
2. Open the receipt drawer.
3. Verify: amount matches order, bank matches student's stated bank, receipt image is legible, scan status is green ("clean").
4. Click **Approve**. This atomically: marks payment PAID, activates enrollment, generates invoice, emails the student.
5. If scan status is "pending", wait a moment and refresh — retry within ~10 seconds.
6. If scan is "infected", **do not approve**. Reject with a note asking the student to re-upload from a clean source.

## 8.3 Refund a payment

1. Finance → Payments → find the payment.
2. Click Refund → choose full or partial → enter reason.
3. For gateway payments (Moyasar/Tamara/Tabby): system fires the refund API to the gateway and marks status `processing`. Watch for status update within ~5 min.
4. For bank transfer: system flags for manual bank refund. You (or Finance) execute the bank transfer manually, then mark **Refund Complete** in the UI.
5. Enrollment is deactivated automatically on refund complete.
6. Student receives an email confirmation.

## 8.4 Publish a new course

1. Get the course draft from the instructor (in Instructor Dashboard).
2. Admin → Courses → find the course → Review tab.

3. Verify: syllabus present, cover image uploaded, CME hours configured, price set, materials approved.
4. Click **Publish**. The course appears in the public catalog immediately.
5. Optionally: Send a broadcast email via **Templates** → **Course Announcement** template.

## 8.5 Respond to a support ticket

1. People → Support → filter to unassigned.
2. Assign to yourself (or a support team member).
3. Read the ticket. Reply with resolution or ask for more info.
4. If the ticket needs another department's input, use **Loop In** to add them to the thread.
5. Close the ticket when resolved. Student gets an email.

## 8.6 Send a broadcast notification

1. Admin → Notifications → New Broadcast.
2. Choose audience: all users / by role / by course enrollment.
3. Write subject + body (EN + AR).
4. Preview → Send. The system enqueues via Cloud Tasks and delivers in batches.
5. Delivery status shows in the Notifications history.

## 8.7 Toggle maintenance mode

1. Admin → Settings → Maintenance.
2. Toggle **Maintenance mode: ON**.
3. Set the banner message (EN + AR) — this is what users see.
4. Save. The platform returns HTTP 503 with your banner for all non-admin routes; admins can still work.
5. When done: toggle OFF. Users see the site again immediately.

## 8.8 Reset a user's password (admin-triggered)

1. Admin → Users → find user → **Send Password Reset**.
2. The user receives an email with a reset link.
3. This does NOT show you their password (there isn't one you can see — passwords are hashed with argon2).

## 8.9 Read the audit log

1. Insights → Logs.
2. Filter by: user email, action type (login, refund, delete, etc.), date range.
3. Every meaningful action writes here: logins, admin promotions, course publishes, refunds, PDPL requests, template edits, feature-flag toggles.

4. Exports to CSV — auditors will ask for this.

### 8.10 Create a backup snapshot (on demand)

1. Admin → Settings → System → Backups tab.
2. Click **Create Backup Now**. The backup lands in `physioguidance-backups` bucket.
3. **Backups are not one-click restored in place** — deliberate design choice. Restore is always **to a clone**. See §9.2.

---

## 9. Emergency runbooks

### 9.1 Site is down / 5xx spike

**Symptoms:** Monitoring shows a red service. Users report the site is unreachable. Sentry error rate is 10x baseline.

**Step 1: Identify the scope.**

- Just one service (e.g. api down but web up)? → §9.1a
- Every service down? → §9.1b
- Slow, not down? → §9.1c

**§9.1a — one service down**

1. Check Cloud Run logs: GCP Console → Cloud Run → the failed service → Logs.
2. Look for the first error in the last 30 min.
3. Most common: DB connection error → check §9.2. Missing env var → someone rotated a secret without redeploying — redeploy that service.
4. If unclear: roll back to previous revision. Cloud Run → the service → Revisions → click the previous good one → Manage traffic → 100%. Cost is a few seconds' downtime while it warms.

**§9.1b — everything down**

1. Check https://status.cloud.google.com — is me-central2 red? If yes → §9.4 regional outage.
2. Check Cloud SQL: `gcloud sql instances describe physioguidance-db-me --format="value(state)"` → should be `RUNNABLE`. If not → §9.2.
3. Check Cloud Run per-service revision counts — did someone deploy something bad to all services at once? Roll back each.
4. If truly stumped: enable maintenance mode (§8.7) to stop the bleeding, then debug.

**§9.1c — slow, not down**

1. Monitoring → Cloud SQL → CPU + connections. If CPU >80%, a slow query is running — check Cloud SQL Query Insights.
2. Monitoring → Redis → memory. If >80%, cache is under pressure.
3. Sentry Performance tab → slowest endpoints today.

### 9.2 Cloud SQL is down or corrupted

See regional-failure-playbook.md — §4.1 (zone outage) and §4.2 (data corruption/PITR restore). Both procedures include full copy-paste `gcloud` commands.

**Key rule: never PITR-restore in place.** Always clone to a new instance, verify the data, then either promote the clone or export the missing rows into production.

### 9.3 Payments stuck / a gateway returns errors

**Symptoms:** Students report "payment stuck at processing." Finance sees pending webhooks not resolving.

1. Finance → Payments → filter by status = `processing`. If just one, likely a stray gateway timeout. Click Reconcile Now.
2. If many: the reconciliation cron may be down. Check Monitoring → Background Jobs → `webhook-reconciliation` — did the last run succeed?
3. If the gateway itself is down: check the gateway's status page (Moyasar, Tamara, Tabby all publish). If confirmed vendor outage: post a maintenance banner (§8.7) but do NOT toggle full maintenance — other payment methods still work.
4. Manual reconciliation: for a specific payment, get the gateway's transaction ID and click Reconcile Now. System re-fetches status from the gateway.

### 9.4 Regional outage (me-central2)

See regional-failure-playbook.md §2.2 and §4.4.

**Bottom line:** wait for GCP. PDPL/SDAIA forbid cross-region failover — customer data must stay in Saudi Arabia. Post a maintenance banner via a static page hosted on your domain registrar's holding-page feature.

### 9.5 Suspected credential compromise

1. Immediately rotate the affected credential. See secrets-rotation-plan.md for the per-secret runbook.
2. If it's a JWT_REFRESH_SECRET or PII_ENCRYPTION_KEY compromise: expect universal forced re-login (JWT case) or a re-encryption migration (PII case).
3. Audit the Logs page for any suspicious action attributed to the compromised credential's usage.
4. Force-reset all admin passwords (Admin → Users → filter by role=admin → bulk Send Reset).
5. Contact SDAIA + NELC if any customer PII may have been exposed — 72h notification window per PDPL Article 27.

### 9.6 Malware detected in student upload

Malware scanner catches this automatically — file is moved to `physioguidance-quarantine` bucket, receipt is marked `scan_status = infected`, admin can't approve, download endpoint returns 403. See malware-unscanned-file-gate.md.

**Your action:** reject the receipt with a note to the student asking for re-upload from a clean source.

**If quarantine bucket grows large:** it retains infected files for 30 days for forensic review. Older files auto-delete.

---

## 10. Deployment — how code gets to production

- **Source of truth:** GitHub repo → main branch. Every merge to `main` triggers CI/CD.
- **Workflows:** `.github/workflows/deploy-{backend,frontend,worker,strapi}.yml`. Each is path-scoped so only affected services rebuild.
- **Build → Deploy:** GitHub Actions builds Docker image → pushes to GCP Artifact Registry → deploys to Cloud Run.
- **Roll back:** GCP Console → Cloud Run → service → Revisions → click previous good revision → 100% traffic.
- **CI failure:** GitHub Actions shows red on the commit. Click into the run for logs. Most common: TypeScript errors, missing translation keys (i18n check runs pre-build), or lint failures.
- **Do NOT run local `docker compose` for production.** Only `infra/*/deploy.sh` scripts. See feedback_deploy_production — hard-learned lesson.

**Manual deploy (only if CI is down):** SSH-less — from a machine with `gcloud` auth:

```
cd /path/to/physioguidance
./infra/backend/deploy.sh   # or frontend/worker/strapi/malware-scanner
```

---

## 11. Cost management

**Current budget:** 1,000 SAR/month (see budget-alert-status.md — you set this in console). **Current monthly cost:** ~515 SAR/month (see cost-tally.md).

**Alerts fire at:** 50% / 90% / 100% / 120% of budget → email to you.

**Cost drivers (largest first):**

1. Cloud Run (all 5 services + 25 jobs) — scales with traffic

2. Cloud SQL (db-g1-small ZONAL) — flat ~150 SAR
3. Storage (buckets + backups) — grows with content
4. Egress (data leaving GCP) — scales with users

**Cost levers you can pull:**

- Scale Cloud Run to `min instances: 0` for low-traffic services → cold start on first request, saves idle cost.
- Shrink Cloud SQL to `db-f1-micro` when traffic is very low. Requires downtime (~5 min).
- Delete stale backups older than compliance requires (currently 7 days automated retention).
- Reduce worker memory from 1.5 GiB → 1 GiB after monitoring shows peak <400 MiB.

**Cost anti-patterns to avoid:**

- Multi-region storage (blocked by SDAIA anyway).
- Cloud SQL REGIONAL availability (worth it, but only after revenue justifies +$45/mo).
- Verbose Cloud Logging retention (default 30 days is enough).

---

# 12. Compliance runbook

## 12.1 PDPL right-to-access request

1. Student emails or opens support ticket asking for their data.
2. You go to Admin → Compliance → PDPL Requests → New Data Export.
3. Enter the student's email. System generates a full data export (JSON + CSV) and stores in `physioguidance-private` bucket.
4. Signed URL emailed to the student's verified address. Expires in 7 days.
5. Log the request in the PDPL Requests table (auto-logged).

**SLA: 30 days maximum** (Article 12).

## 12.2 PDPL right-to-erasure request

1. Student initiates via Settings → Privacy → Delete Account (they own this flow).
2. Or you initiate on their behalf: Admin → Users → find user → Delete Account → confirm.
3. System: soft-deletes user record + PII fields nulled/hashed, waits 30 days grace (student can cancel), then hard-deletes.
4. Certain fields are legally retained (invoice records for tax, NELC audit records) — this is documented in pdpl-controls-matrix.csv.

**Grace period: 30 days** (cancellable). **SLA: 30 days after grace = 60 days total**.

### 12.3 Inactive user auto-deletion

Documented in pdpl-inactive-user-policy.md. Automatic:

- User inactive 24 months + no active enrollments → warning email + 30-day grace.
- If they log in during grace, deletion is cancelled.
- Otherwise: hard-delete.

**Your action:** none. It's automatic. But check monthly log to confirm the job ran.

### 12.4 NELC audit request

1. NELC or SCFHS requests activity records.
2. Admin → Compliance → SCFHS Export → date range → download CSV.
3. Send to the requester via their designated channel.
4. Every export is logged (Logs page).

### 12.5 SDAIA data-residency question

- All data is in me-central2 (Saudi). Confirmed via regional-failure-playbook.md §1.
- Backups are in me-central2. Deliberately not cross-region (SDAIA + PDPL).
- Data classification: pdpl-data-classification.csv enumerates every PII field.

---

## 13. What we intentionally did NOT build

Full list with rationale:

- **Multi-region hot standby** — blocked by SDAIA (no second Saudi region exists).
- **Cross-region backups** — blocked by PDPL.
- **Cloud SQL REGIONAL** availability — worth ~$45/mo, but not until revenue justifies. Documented in regional-failure-playbook.md §7.3.
- **STANDARD_HA Redis with persistence** — worth ~$34/mo, not needed at current traffic. Documented in redis-persistence-risk.md §6.
- **xAPI statement replay outbox** — small analytics gap accepted. Documented in redis-persistence-risk.md §6.3.
- **In-place backup restore** — deliberate. Only clone-restore. See backup system decision memory.
- **One-click deploy from admin UI** — everything ships via GitHub CI/CD, never a button in the app.
- **PII_ENCRYPTION_KEY scheduled rotation** — needs migration script. Rotate only on suspected compromise. See secrets-rotation-plan.md.
- **Zero-downtime JWT_REFRESH_SECRET rotation** — rotation intentionally invalidates all sessions. Communicate 24h in advance.

- **Impersonation feature for admins** — use a real test account instead.
- **Cron polling replaced by Cloud Tasks** — event-driven scheduling; watch job history in Monitoring → Background Jobs.
- **Malware gate on public bucket** — public bucket holds self-generated content (invoices) + course materials with downstream processing. Documented in malware-unscanned-file-gate.md §5.

Every "not built" decision is an accepted risk with a documented revisit trigger. Revisit them at the cadences noted in each doc.

---

# 14. Where to find things

## 14.1 Handover folder (this folder)

```
PhysioGuidance-Handover/
├── platform-owner-guide.md          ← you are here
├── repo-verification.md              — repo URL, SHA, clean-machine build steps
├── wif-setup-for-amna.md             — GitHub → GCP auth (WIF), how to re-do if needed
├── least-privilege-service-accounts-for-amna.sh — SA cleanup script
├── third-party-services-ownership.csv — 17 vendors, who owns each account
├── cost-tally.md                     — monthly resource inventory + estimate
├── budget-alert-status.md            — how to create your 1,000 SAR budget
├── alert-recipients-status.md        — you're on all 6 alerts; Ghulam-removal script
├── secrets-rotation-plan.md          — every secret + how to rotate
├── secrets-rotation-log.md           — append-only rotation log (empty, ready to use)
├── redis-persistence-risk.md         — what breaks if Redis restarts
├── regional-failure-playbook.md      — full DR playbook with copy-paste commands
├── malware-unscanned-file-gate.md    — malware gate design + verification steps
├── pdpl-controls-matrix.csv          — 30-row PDPL controls evidence
├── pdpl-data-classification.csv      — every PII field classified
├── pdpl-inactive-user-policy.md      — 24-month inactive-user policy
├── nelc-evidence-matrix.csv          — NELC audit evidence rows
├── nelc-screenshots/                 — screenshots for NELC evidence
└── NELC-EVIDENCE-README.md           — how to use the NELC evidence bundle
```

## 14.2 External dashboards

- **GCP Console:** https://console.cloud.google.com — everything infra
- **Cloud Run:** https://console.cloud.google.com/run?project=physioguidance
- **Cloud SQL:** https://console.cloud.google.com/sql/instances?project=physioguidance
- **Secret Manager:** https://console.cloud.google.com/security/secret-manager?project=physioguidance
- **IAM:** https://console.cloud.google.com/iam-admin/iam?project=physioguidance
- **Billing:** https://console.cloud.google.com/billing

- **Sentry:** your Sentry project URL — error tracking
- **GitHub:** https://github.com/physioguidance1-arch/physioguidance — source of truth
- **GitHub Actions:** https://github.com/physioguidance1-arch/physioguidance/actions — CI/CD
- **Strapi admin:** https://cms.physioguidance.org/admin — blog + static content
- **Moyasar dashboard:** https://dashboard.moyasar.com
- **Tamara dashboard:** https://partners.tamara.co
- **Tabby dashboard:** https://merchant.tabby.ai
- **Zoom Marketplace:** https://marketplace.zoom.us — your S2S OAuth app

### 14.3 The code

- **Backend (NestJS):** `backends/` — API, business logic, jobs, workers, controllers.
- **Frontend (Next.js 15):** `frontend/` — the web app for all roles.
- **CMS (Strapi 5):** `cms/` — Strapi config + custom controllers.
- **Malware scanner:** `infra/malware-scanner/` — ClamAV in Cloud Run.
- **Deploy scripts:** `infra/*/deploy.sh` — one per service.
- **CI workflows:** `.github/workflows/deploy-*.yml`.
- **Database schema:** `backends/src/database/schema/*.ts` (Drizzle ORM).
- **Migrations:** `backends/src/database/migrations/*.sql` + `_journal.json`.

### 14.4 Assistant memory (this project)

Location: `~/.claude/projects/-Users-macbookair-Developer-physioguidance/memory/`

- `MEMORY.md` — index
- Individual memory files — architecture patterns, feedback, project context
- These persist across Claude sessions. Update when policy changes.

---

# 15. Escalation path

| Issue | First action | If unresolved |
|---|---|---|
| Site down, cause unclear | This guide §9.1 | Ghulam (handover contact) |
| Cloud SQL issue | This guide §9.2 → regional-failure-playbook.md | GCP Support case (paid support tier) |
| Payment gateway rejected | Gateway's own dashboard first | Their support: Moyasar / Tamara / Tabby |
| PDPL question | pdpl-controls-matrix.csv | Legal counsel |
| NELC integration issue | Compliance page + NELC evidence bundle | NELC integration desk |
| SDAIA compliance question | This guide §12.5 | Legal counsel |
| Sentry alert | Sentry issue detail | Ghulam (if it references code) |
| Cost spike alert | This guide §11 | GCP billing support |

**Ghulam (handover contact):** ghulam@physioguidance.org **Availability:** 30-day handover window post-signoff — after that, engagement-based.

# 16. Cadence checklist (print this)

**Every business morning** (10 min)

- ☐ Monitoring page — all green
- ☐ Pending bank-transfer receipts
- ☐ Pending role requests
- ☐ Support tickets — assigned
- ☐ Logs — no unusual admin action last 12h
- ☐ Sentry — no error-rate spike

**Every Monday** (30 min)

- ☐ Cost review (last 7d vs prior 7d)
- ☐ User growth trend
- ☐ Certificate spot-check (3 random)
- ☐ Refund queue — none >7 days

- [ ] Backup existence check

**First Monday of the month** (2 hours)

- [ ] Secrets check — any >12 months old?
- [ ] IAM audit — any departed team members still in?
- [ ] PDPL request log — any past 30-day SLA?
- [ ] NELC monthly export → shared drive
- [ ] Cost forecast — within 1,000 SAR budget?

**Quarterly** (half day)

- [ ] DR rotation drill — rotate one low-blast-radius secret (see secrets-rotation-plan.md §7)
- [ ] Backup restore drill — clone to test instance, verify data (see regional-failure-playbook.md)
- [ ] Read all 3 "risk" docs top-to-bottom — has anything changed?

**Annually**

- [ ] Rotate JWT_SECRET + JWT_REFRESH_SECRET (see plan)
- [ ] Refresh all 3rd-party API keys
- [ ] Update this Platform Owner Guide with anything you learned

---

**End of guide.** Keep this file within reach. Update it when the platform changes.